

INGENIERÍA DE SOFTWARE III

Auditoría de
sistemas de
información



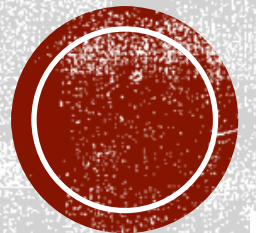
OBJETIVO

Explicar las motivaciones para auditar sistemas de información y el concepto de auditoría de sistemas de información.

AGENDA

- | | | |
|---|-----------|---|
| 1 | CONTROLES | ¿Cuáles son los controles de sistemas? |
| 2 | RIESGOS | ¿Cuáles son los riesgos de una auditoría? |

OBJETIVO Y AGENDA





CONTROLES Y RIESGOS



RAZONES PARA CONTROLAR

1) Hacking

2) virus

3) acceso físico ilegal

4) abuso de privilegios

Costos por abusos
computacionales

1) pérdida de vida humana,

2) privación de libertad,

3) daño al medio ambiente.

Costos por errores de
computación

1) Software - ¿qué pasa si se destruye?

2) Personal - ¿qué pasa si un profesional calificado
deja la empresa?

Valor de hardware,
software y personal

Costos por toma de
decisiones incorrectas

Ejemplo: cálculo de amortización
erróneo en un bien de poco valor.

Costos por
pérdida de datos

Pérdida de cuentas corrientes, pérdida
de los datos de los alumnos

Evolución
controlada de TI

Las consecuencias de usar
sistemas no confiables puede
ser catastrófica.

Mantenimiento
de privacidad

Muchos datos se recolectan sobre
los individuos: impuestos, obras
sociales, trabajo, residencia.



AUDITORÍA DE SISTEMAS DE INFORMACIÓN

AUDITORÍA DE SISTEMAS DE INFORMACIÓN

Definición:

La auditoría de sistemas de información es el proceso de recolectar y evaluar evidencia para determinar si:

- 1) el sistema automático preserva los activos,
- 2) mantiene la integridad de los datos,
- 3) permite que los objetivos organizacionales se alcancen con eficacia,
- 4) usa los recursos con eficiencia.

MOTIVACIÓN

Lo han designado Gerente del Departamento de Auditoría de la Empresa “X”.

La empresa posee:

- 520 programadores y analistas
- 1245 PC's conectadas en red
- 5378 bases de datos.

Pregunta: ¿cómo puede ejecutar la auditoría, de tal forma de obtener una seguridad razonable sobre:

- 1) la salvaguarda de activos en el procesamiento de datos,
- 2) integridad de los datos,
- 3) la eficiencia y eficacia de los sistemas ?

SOLUCIÓN

- Implementar sistemas de control.
 - 1) saber qué es un control y cómo funcionan los controles
 - 2) determinar qué controlar
 - 3) estimar la confiabilidad de los controles
 - 4) estimar el riesgo de la auditoría

LA NATURALEZA DE LOS CONTROLES

Definición.

Un **control** es un sistema que previene, detecta, o corrige eventos ilegales.

Hay tres aspectos claves en esta definición:

- 1) un control es un sistema
- 2) eventos ilegales
- 3) los controles son usados para prevenir, detectar o corregir eventos ilegales.

UN CONTROL ES UN SISTEMA

Una password, ¿es un control ?

- Habitualmente, tendemos a nombrar los controles, teniendo en cuenta sólo un aspecto del control.
- Una password se convierte en control, sólo en el contexto de un sistema que asegure:
 - 1) seguridad para elegir passwords,
 - 2) correcta validación de passwords,
 - 3) almacenamiento seguro de las passwords,
 - 4) seguimiento en el uso indebido de passwords
 - 5)...

CONTROL DE EVENTOS ILEGALES

- ¿Cómo puede surgir un evento ilegal?
 - 1) si se ingresan al sistema inputs no autorizados, inexactos, incompletos, redundantes, ineficaces o ineficientes,
 - 2) si el sistema transforma el input de una manera no autorizada, inexacta, incompleta, ineficiente o ineficaz

- Ejemplos:
 - 1) inputs incorrectos en un programa interactivo.
 - 2) un programa que contiene instrucciones erróneas que resultan en una ejecución incorrecta.

TIPOS DE CONTROLES

- **Control Preventivo:**

- instrucciones de cómo completar un formulario.

Nota: las instrucciones no son el control.

- **Control Detectivo:**

- un programa que valida datos de input, rechazando los erróneos.

- **Control Correctivo:**

- un programa que detecta el ruido en comunicaciones y permite corregir datos corruptos.

OBJETIVO DE LA AUDITORÍA

Reducir las pérdidas esperadas por eventos ilegales mediante:

- 1) **controles preventivos**: reducen la probabilidad que estos eventos ocurran.
- 2) **controles detectivos y correctivos**: reducen la cantidad de pérdidas cuando los eventos ilegales ocurren.

La tarea del auditor es determinar si los controles están ubicados y funcionan para prevenir los eventos ilegales.

¿CÓMO ADMINISTRAR LA COMPLEJIDAD?

Para administrar la complejidad, se sugiere:

- 1) **factorizar** el sistema en subsistemas
- 2) **determinar la confiabilidad de cada subsistema**, y las implicancias de cada uno de ellos en el nivel de confiabilidad general del sistema.

FACTORIZACIÓN

El primer paso para comprender un sistema complejo es partitionarlo en subsistemas.

Un **subsistema** es un componente de un sistema que:

- 1) realiza ciertas funciones básicas necesarias para el sistema en general,
- 2) le permite atender sus objetivos fundamentales.

Los subsistemas son componentes lógicas y no físicas.

El proceso de partitionar en subsistemas se denomina **factorización**.

CÓMO FACTORIZAR

Para poder factorizar, se necesita un criterio.

Criterio: La esencia de un subsistema es la **función** que realiza.

Los auditores deben identificar primero, las principales funciones que el sistema realiza para cumplir sus objetivos.

El proceso de factorización termina cuando se ha particionado el sistema en partes lo suficientemente pequeñas, de tal modo que puedan ser entendidas y evaluadas.

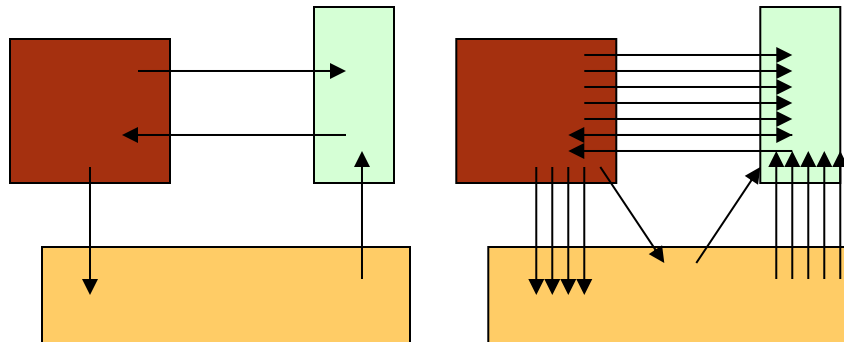
OTRO CRITERIO DE FACTORIZACIÓN

Además de las funciones, existen otras dos guías:

ACOPLAMIENTO

Cada subsistema debería ser relativamente independiente de otros subsistemas.

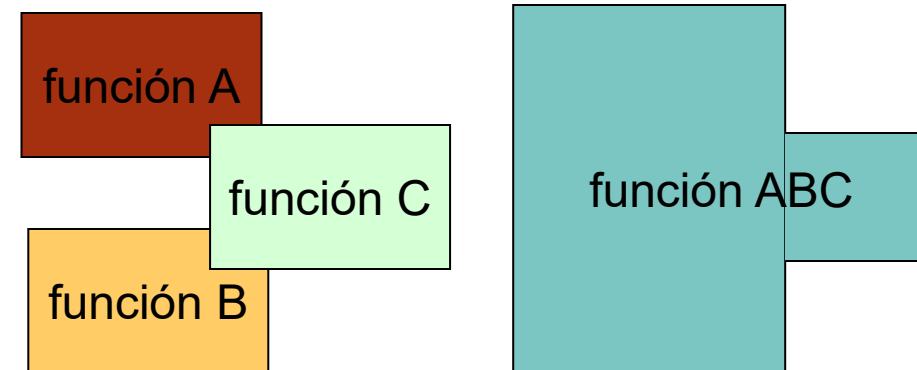
Sistemas con poco acoplamiento son más fáciles de comprender.



COHESIÓN

Cada subsistema debe ser internamente cohesivo.

Todas las actividades realizadas por el sistema apuntan a cumplir la función principal del subsistema.



FORMAS DE FACTORIZACIÓN

- 1) **funciones gerenciales** - las funciones que se deben realizar para asegurar que el desarrollo, la implementación, operación y mantenimiento de los sistemas de información proceden de una forma planificada y controlada.
- 2) **funciones de aplicación** - tareas que son necesarias ejecutar para realizar un procesamiento de información confiable. Relacionado con “ciclos”.

EN BASE A FUNCIONES GERENCIALES

Subsistema Gerencial	Descripción
Alta gerencia	Debe asegurar que las funciones de los SI estén bien administradas. Decisiones de políticas a largo plazo de cómo serán usados los SI.
Gerencia de Sistemas de Información	Responsabilidad general de planificar y controlar todas las actividades de los SI. Aconseja a la alta gerencia de las decisiones políticas de largo plazo y las traduce en metas y objetivos de corto plazo.

Subsistema Gerencial	Descripción
Gerencia de Desarrollo de Sistemas	Responsable del diseño, implementación y mantenimiento de los sistemas.
Gerencia de Programación	Responsable de la programación de nuevos sistemas, mantenimiento de los viejos y soporte general.
Administración de Datos	Responsable de lograr los objetivos de planificación y control en relación al uso de los datos de la organización.

Subsistema Gerencial	Descripción
Gerencia de Aseguramiento de Calidad	Responsable de asegurar que el desarrollo, operación y mantenimiento de los sistemas es conforme a los estándares de calidad establecidos.
Administración de Seguridad	Responsable por los controles de acceso y seguridad física de las funciones de los SI.
Gerencia de Operaciones	Responsable de la planificación y control de las operaciones diarias.

Ingeniería de Software III

2026

EN BASE A FUNCIONES DE APLICACIÓN - 1

- Los sistemas de información que soportan una organización, se dividen en **ciclos**.
- Los ciclos varían de acuerdo al tipo de organización: industria, entidad financiera, etc.
 - En general incluyen:
 - 1) ventas y cobranzas,
 - 2) administración de personal, sueldos y jornales,
 - 3) compras y pagos,
 - 4) producción, inventario y almacenaje,
 - 5) tesorería (contabilidad).

EN BASE A FUNCIONES DE APLICACIÓN - 2

- Cada ciclo es factorizado en uno o más sistemas de aplicación.
- Ejemplo: Ventas puede subdividirse en:
 - 1) administración de clientes
 - 2) captura de pedidos
 - 3) facturación
- El conjunto de subsistemas de aplicación incluyen lo siguiente:

EN BASE A FUNCIONES DE APLICACIÓN - 3

Subsistema de Aplicación	Descripción
Limítrofe	Componentes que establecen las interfaces entre el usuario y el sistema.
Input	Componentes que capturan, preparan e ingresan comandos y datos al sistema.
Comunicaciones	Componentes que transmiten datos entre los subsistemas y sistemas.

Subsistema de Aplicación	Descripción
Procesamiento	Componentes que realizan toma de decisiones, cálculos, clasificación, ordenamiento y sumarización de datos dentro del sistema.
Base de Datos	Componentes que definen, agregan, acceden, modifican o eliminan datos.
Output	Componentes que buscan y presentan los datos al usuario.

CONFIABILIDAD DE SUBSISTEMAS

Primero - determinar el menor nivel de los subsistemas.

Segundo - evaluar la confiabilidad de los controles en cada subsistema.

CONFIABILIDAD DE CONTROLES

- Para evaluar la confiabilidad de los controles:
 - 1) se deben identificar todos los posibles tipos de eventos que pueden ocurrir en el subsistema.
 - 2) se deben considerar todos los eventos válidos o ilegales.
- Para identificar los eventos, hay que **considerar las principales funciones** que realiza el subsistema.

CONSIDERAR LAS PRINCIPALES FUNCIONES

- Para cada función:
 - 1) analizar cómo debería realizarse
 - 2) evaluar cómo el subsistema cumple con esa visión normativa.

Para determinar si un evento es legal o ilegal se deben considerar las transacciones que pueden ocurrir como input al subsistema.

- Todos los eventos en un sistema de aplicación deben surgir de una transacción.

EVENTOS Y TRANSACCIONES

- Cuando un evento ocurre, el sistema recibe una transacción de input.
- Cuando la transacción se recibe como input el sistema cambia de estado.
- Otros cambios de estado ocurren a medida que el sistema procesa la transacción.
Ejemplo: toma de pedidos.
- Para identificar todos los eventos que pueden ocurrir en un sistema como resultado de la transacción, se debe entender cómo el sistema procesa la transacción.

PROCESAMIENTO DE TRANSACCIONES

- Generalmente los auditores aplican técnicas de walk-through (recorrido):
 - 1) se considera una transacción particular,
 - 2) se identifican todos los componentes del sistema que procesan la transacción
 - 3) se trata de entender cada paso de procesamiento que ejecuta cada componente
 - 4) se considera cualquier error o irregularidad (evento ilegal) que pueda ocurrir en el camino.

CLASES DE TRANSACCIONES

- Generalmente es muy costoso realizar este proceso para todas las transacciones.
- Por eso, se trabaja con **clases de transacciones**:
 - 1) se agrupan transacciones que tengan un procesamiento similar,
 - 2) se trata de entender esas transacciones, y los eventos que puedan surgir como resultado de esas transacciones como grupo,
 - 3) se tratan sólo aquellas transacciones que se consideran importantes para los objetivos de la auditoría.

¿QUÉ EVENTOS?

Usando esta técnica, no se identifican todos los eventos que puedan surgir en un sistema.

A pesar de esto, los auditores deberían examinar todas aquellas transacciones y eventos que consideren importantes.

Una vez que se han identificado los eventos que pueden ocurrir, los auditores deben evaluar:

- 1) si los controles están correctamente ubicados, y
- 2) si funcionan para detectar eventos ilegales.

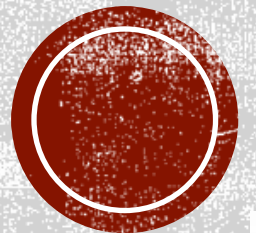
OBJETIVO

Explicar las motivaciones para auditar sistemas de información y el concepto de auditoría de sistemas de información.

AGENDA

- | | | |
|---|-----------|---|
| 1 | CONTROLES | ¿Cuáles son los controles de sistemas? |
| 2 | RIESGOS | ¿Cuáles son los riesgos de una auditoría? |

OBJETIVO Y AGENDA



RIESGOS DE LA AUDITORÍA

Recordemos los objetivos de la auditoría:

- 1) salvaguardar activos
- 2) asegurar integridad de los datos
- 3) asegurar que los sistemas son efectivos
- 4) asegurar que los sistemas son eficaces

Para poder cumplir con los objetivos, se debe recolectar evidencia.

Para esto, se debe medir, y se podría fallar al detectar las pérdidas materiales reales o potenciales.

DEFINICIÓN DE RIESGO

Definición

El **riesgo de auditoría** es el riesgo de que un auditor fracase al detectar las pérdidas materiales reales, o potenciales, o los registros incorrectos.

$$RDA = RI * RC * RD$$

RDA: Riesgo Deseado de Auditoría

RI: Riesgo Inherente

RC: Riesgo de Control

RD: Riesgo de Detección

TIPO DE RIESGOS

- 1) **Riesgo Deseado**: el riesgo que se desea correr.
- 2) **Riesgo Inherente**: refleja la probabilidad que una pérdida material o una imputación errónea exista en algún segmento de la auditoría, antes de que sea considerada la confiabilidad de los controles internos.
- 3) **Riesgo de Control**: refleja la probabilidad que en algún segmento de la auditoría, los controles internos no prevengan, detecten o corrijan pérdidas materiales o imputaciones erróneas que puedan surgir.
- 4) **Riesgo de Detección**: refleja la probabilidad que los procedimientos de auditoría utilizados en algún segmento, fallen en detectar pérdidas materiales o imputaciones erróneas.

1) RIESGO DESEADO PARA UNA AUDITORÍA

- Primero los auditores eligen el nivel de **RDA**.

Evalúan las consecuencias de fracasar en detectar las pérdidas materiales reales o potenciales

2) RIESGO INHERENTE DE SISTEMAS

- Luego, se considera el nivel de **RI**.
- Los auditores consideran factores generales tales como:
 - 1) la naturaleza de la organización (la posición en el mercado),
 - 2) la industria en la que opera (¿la industria está sujeta a cambios rápidos?)
 - 3) las características del gerenciamiento (¿es agresivo y autocrático?)
 - 4) intereses contables y de auditoría (¿se usan técnicas?)

2) RIESGO INHERENTE DE SISTEMAS - ¿CÓMO?

Se consideran luego los RI asociados con diferentes segmentos de la auditoría (ciclos, sistemas de aplicación, ...).

- Para cada segmento, se consideran factores tales como:
 - 1) sistemas financieros
 - 2) sistemas estratégicos
 - 3) sistemas de operación crítica
 - 4) sistemas de tecnología avanzada

2) RIESGO INHERENTE DE SISTEMAS

▪ RIESGO INHERENTE DE SISTEMAS FINANCIEROS

- Proveen controles financieros sobre los principales activos de la organización.
- Poseen alto RI.
- Son el blanco de acciones delictivas y fraudes.
- Ejemplo: sistema de facturación

▪ RIESGO INHERENTE DE SISTEMAS ESTRATÉGICOS

- Proveen ventajas competitivas para la organización.
- Comprometen clientes, proveedores, secretos de marca.
- Tienen alto RI.
- Son blanco de espionaje industrial, o acciones indebidas de la competencia.
- Ejemplo: el sistema que soporta la operatoria comercial de una empresa

2) RIESGO INHERENTE DE SISTEMAS

- **RIESGO INHERENTE DE SISTEMAS DE OPERACIÓN CRÍTICA**
 - Aquellos sistemas que pueden paralizar a la organización si fallan.
 - Generalmente tienen alto RI.
 - Ejemplo: sistemas de control de producción, sistemas de reservas.
- **RIESGO INHERENTE DE SISTEMAS DE TECNOLOGÍA AVANZADA**
 - Sistemas que usan tecnología de punta.
 - Tienen alto RI, debido a la falta de experiencia en ese tipo de sistemas.

3) RIESGO DE CONTROL

Para evaluar el nivel de **RC** asociado con cada segmento de la auditoría, se debe considerar la confiabilidad de los controles gerenciales y de aplicación.

Generalmente, se identifican y evalúan primero los controles en los subsistemas gerenciales.

CONTROLES GERENCIALES

- Los controles gerenciales actúan como **capas de cebolla** protectivas, por encima de los controles de aplicación.



Alta Gerencia
Gerencia de Sistemas de Información
Gerencia de Desarrollo de Sistemas
Gerencia de Programación
Administración de Datos
Aseguramiento de Calidad
Administración de Seguridad
Gerencia de Operaciones



El buen nivel de los controles externos garantizan el nivel de los controles internos.

Los controles gerenciales se evalúan en general, y no para cada aplicación.

4) RIESGO DETECCIÓN

- Finalmente, se calcula el nivel de RD que se debe lograr para cumplir con el RDA.
- Se diseñan procedimientos de recolección de evidencia para intentar lograr el nivel de RD.
- En general:
 - los auditores no recolectan la cantidad de evidencia que ellos desearían
 - deben ser astutos para determinar en dónde aplicar los procedimientos de auditoría, y cómo interpretar la evidencia recolectada.

BIBLIOGRAFÍA Y MATERIAL DE LECTURA

BIBLIOGRAFÍA

Information Systems Audit and Control – Ron Weber – capítulo 2

BIBLIOGRAFÍA ADICIONAL

Information Technology Control and Audit (third edition) – Sandra Senft, Frederick Gallegos – capítulos 2 y 3
